



ASSESSMENT COVERSHEET

Attach this coversheet as the cover of your submission. All sections must be completed.

Section A: Submission Details

Programme : Bachelor Of Information Technology (Hons) In Computer System Security
Course Code & Name : IKB21403 - VULNERABILITY ANALYSIS
Course Lecturer(s) : Nor Adani Kamal Mohamad Nasir
Submission Title : LAB 3 (REAL-WORLD SCENARIO)
Deadline : Day 07 Month 06 Year 2026 Time 11.59pm
Penalties :

- 5% will be deducted per day to a maximum of four (4) working days, after which the submission will **not** be accepted.
- Plagiarised work is an Academic Offence in University Rules & Regulations and will be penalised accordingly.

Section B: Academic Integrity

Tick (✓) each box below if you agree:

- | | |
|-------------------------------------|--|
| ☒ | I have read and understood the UniKL's policy on Plagiarism in University Rules & Regulations. |
| ☒ | This submission is my own, unless indicated with proper referencing. |
| ☒ | This submission has not been previously submitted or published. |
| ☒ | This submission follows the requirements stated in the course. |

Section C: Submission Receipt

(must be filled in manually)

Office Receipt of Submission

Date & Time of Submission (stamp)	Student Name(s)	Student ID(s)
	1 HAZIQ DANIAL BIN NOR AZAN	52215225213

Student Receipt of Submission

This is your submission receipt, the only accepted evidence that you have submitted your work. After this is stamped by the appointed staff & filled in, cut along the dotted lines above & retain this for your record.

Date & Time of Submission (stamp)	Course Code	Submission Title	Student ID(s) & Signature(s)

Contents

1. Objective & Methodology	3
2. Finding A: SSL Weak Cipher	4
2.1 Scanner Finding (What Nessus Reported).....	4
2.2 Manual Validation Command	4
2.3 Actual Output from Kali.....	4
2.4 Analysis	4
2.5 Technical Justification	5
3. Finding B: Open Port with No Authentication	6
3.1 Scanner Finding (What Nessus Reported).....	6
3.2 Manual Validation Command	6
3.3 Actual Output from Kali.....	6
3.4 Analysis	7
3.5 Technical Justification	7
4. Finding C: Outdated Service	8
4.1 Scanner Finding (What Nessus Reported).....	8
4.2 Manual Validation — FTP Service (Port 21).....	8
4.3 Manual Validation — SSH Service (Port 22)	9
4.4 Manual Validation — HTTP Service (Port 80).....	10
5. Summary & Final Verdicts	11
5.1 Key Learning: This Is What Real VA Analysts Do	12

1. Objective & Methodology

Lab 3 trains students to think like professional vulnerability analysts who must defend their findings. The objective is to manually validate scanner findings using command-line tools, then make a professional judgement: is the finding a True Positive, False Positive, or an Accepted Risk?

Key Learning: Blind reporting = bad analyst. A professional does not simply paste scanner output into a report. They must verify each finding manually using tools like Nmap, Netcat, and curl — then provide technical justification for their verdict.

Three scenario findings were selected for manual validation:

- Finding A: SSL Weak Cipher — Does the target actually offer weak SSL/TLS ciphers?
- Finding B: Open Port with No Authentication — Is the Bind Shell on port 1524 truly open and unauthenticated?
- Finding C: Outdated Service — Is the FTP/SSH/HTTP service truly running a vulnerable outdated version?

Manual Validation Tools Used:

Nmap ssl-enum-ciphers	Verify SSL/TLS cipher suites offered by target
nmap -sV	Verify open ports and exact service versions
nc -nv (Netcat)	Banner grab — connect to service and read version banner
curl -I	HTTP header grab — confirm web server version and response

2. Finding A: SSL Weak Cipher

2.1 Scanner Finding (What Nessus Reported)

Finding Name	SSL Version 2 and 3 Protocol Detection
Reported Severity	CRITICAL (CVSS 9.8)
Scanner Claim	Target accepts SSLv2 and SSLv3 connections with weak cipher suites
Affected Port	Port 443/tcp (HTTPS)

2.2 Manual Validation Command

Command run from Kali Linux:

```
nmap --script ssl-enum-ciphers -p 443 192.168.56.106
```

2.3 Actual Output from Kali

Command Run	nmap --script ssl-enum-ciphers -p 443 192.168.56.106
Result	443/tcp filtered https
Nmap Status	Host is up (0.000047s latency) — scan completed in 0.92 seconds
SSL Enumeration Result	NO SSL data returned — port is FILTERED, not OPEN

```
PORT STATE SERVICE
443/tcp filtered https
```

2.4 Analysis

The Nessus scanner reported SSL v2/v3 vulnerabilities on the SMTP (port 25) and PostgreSQL (port 5432) services — NOT on port 443. When we manually verify port 443 specifically using the ssl-enum-ciphers script, the result shows the port is FILTERED, meaning:

- Port 443 is not open on Metasploitable2 (no HTTPS web server is running)
- No SSL/TLS service is exposed on port 443
- The ssl-enum-ciphers script could not enumerate any cipher suites

The scanner's SSL findings are VALID but apply to different ports (25/smtp and 5432/postgresql), not port 443. If we were only checking port 443, this would be a False Positive for that specific port.

2.5 Technical Justification

Verdict Justification:

- Port 443/tcp is FILTERED — no HTTPS service running on Metasploitable2
- SSL weak cipher vulnerability is REAL but exists on ports 25 (SMTP) and 5432 (PostgreSQL), not 443
- The scanner correctly detected SSLv2/v3 on SMTP and PostgreSQL — these are TRUE POSITIVES
- A report that claims SSL weakness on port 443 without manual verification would be INCORRECT
- Professional verdict: Report the SSL weakness on ports 25 and 5432. Clarify that port 443 does not run SSL on this system.

Real-World Lesson:

This is exactly the type of error that causes expensive false remediation in real organizations. If a security team acts on a report saying 'fix SSL on port 443' when no HTTPS service runs there, they waste time and resources. Manual validation prevents this.

3. Finding B: Open Port with No Authentication

3.1 Scanner Finding (What Nessus Reported)

Finding Name	Bind Shell Backdoor Detection
Reported Severity	CRITICAL (CVSS 9.8)
Scanner Claim	Port 1524/tcp is open with a shell that requires no authentication
Affected Port	Port 1524/tcp (wild_shell)
Nessus Evidence	Scanner executed 'id' command and received 'uid=0(root)' response

3.2 Manual Validation Command

Command run from Kali Linux:

```
nmap -sV -p 1524,5900,23 192.168.56.106
```

3.3 Actual Output from Kali

Command Run	nmap -sV -p 1524,5900,23 192.168.56.106
Port 23/tcp	OPEN — telnet — Linux telnetd
Port 1524/tcp	OPEN — bindshell — Metasploitable root shell
Port 5900/tcp	OPEN — vnc — VNC (protocol 3.3)
Service Info	OS: Linux; CPE: cpe:/o:linux:linux_kernel

```
PORT STATE SERVICE VERSION
23/tcp    open  telnet    Linux telnetd
1524/tcp  open  bindshell Metasploitable root shell
5900/tcp  open  vnc       VNC (protocol 3.3)
```

Additional verification — try connecting to port 1524:

```
nc -nv 192.168.56.106 1524
```

Expected result: Immediate root shell prompt (#) without any login required.

3.4 Analysis

Nmap independently CONFIRMS the Nessus scanner finding. Port 1524/tcp is:

- Confirmed OPEN by Nmap
- Identified as 'bindshell' service type — this is NOT a normal service
- Nmap even labels it 'Metasploitable root shell' — directly confirming it is a backdoor
- No authentication required — anyone who connects gets a root shell immediately

The scanner's finding is completely accurate. This is definitively a TRUE POSITIVE with the highest possible severity.

VERDICT: TRUE POSITIVE — CRITICAL SEVERITY

3.5 Technical Justification

Verdict Justification:

- Nmap independently confirms port 1524 is OPEN with a bind shell service
- The service banner explicitly identifies it as a 'Metasploitable root shell'
- No authentication credentials are required to access the shell
- Nessus further confirmed this by executing 'id' and receiving root-level response
- TWO independent tools (Nessus + Nmap) both confirm — extremely high confidence TRUE POSITIVE
- This is NOT a false positive — the backdoor is genuinely present and immediately exploitable

Real-World Lesson:

When two independent tools (Nessus scanner AND Nmap manual verification) both confirm the same finding, the confidence level is very high. In a real VA engagement, this would be marked CRITICAL and escalated immediately to the client as a Priority 1 finding requiring same-day remediation.

4. Finding C: Outdated Service

4.1 Scanner Finding (What Nessus Reported)

Finding Name	Outdated/Vulnerable Service Versions Detected
Scanner Claim	Multiple services running outdated versions with known CVEs
Services of Interest	FTP (vsftpd), SSH (OpenSSH), HTTP (Apache)
Purpose	Verify actual versions via banner grab and compare to known vulnerability databases

4.2 Manual Validation — FTP Service (Port 21)

Command run:

```
nc -nv 192.168.56.106 21
```

Actual Banner Received:

```
(UNKNOWN) [192.168.56.106] 21 (ftp) open
220 (vsFTPd 2.3.4)
```

Service	FTP (vsftpd)
Version Detected	vsftpd 2.3.4
CVE Reference	CVE-2011-2523
CVE Description	vsftpd 2.3.4 contains a deliberately introduced backdoor. Appending ':' to the username triggers a root shell on port 6200. CVSS 10.0 CRITICAL.
Is Version Vulnerable?	YES — vsftpd 2.3.4 is THE backdoored version. Current stable is 3.0.5
Vendor Advisory	Backdoor was introduced June 30-July 1 2011 and removed July 3 2011. Only this specific build is affected.
Verdict	TRUE POSITIVE — CRITICAL (CVE-2011-2523)

4.3 Manual Validation — SSH Service (Port 22)

Command run:

```
nc -nv 192.168.56.106 22
```

Actual Banner Received:

```
(UNKNOWN) [192.168.56.106] 22 (ssh) open
SSH-2.0-OpenSSH_4.7p1 Debian-8ubuntu1
```

Service	SSH (OpenSSH)
Version Detected	OpenSSH 4.7p1 Debian-8ubuntu1
Release Year	2007 — approximately 19 years old
CVE Reference	CVE-2008-5161
CVE Description	OpenSSH 4.7p1 in CBC mode allows remote attackers to recover partial plaintext from ciphertext in SSH sessions. CVSS 2.6 LOW.
Additional Context	OpenSSH 4.7p1 is NOT affected by RegreSSHion (CVE-2024-6387) which affects versions 8.5p1-9.7p1
Is Version Vulnerable?	PARTIALLY — CVE-2008-5161 is low severity; version is very old but main risk is lack of modern features (no curve25519, no ChaCha20)
Verdict	TRUE POSITIVE — LOW/MEDIUM (Outdated, Accepted Risk possible)

4.4 Manual Validation — HTTP Service (Port 80)

Command run:

```
curl -I http://192.168.56.106
```

Actual Response Headers:

```
HTTP/1.1 200 OK
Date: Sat, 23 May 2026 14:16:13 GMT
Server: Apache/2.2.8 (Ubuntu) DAV/2
X-Powered-By: PHP/5.2.4-2ubuntu5.10
Content-Type: text/html
```

Service	HTTP (Apache)
Apache Version	Apache/2.2.8 (Ubuntu)
PHP Version	PHP/5.2.4-2ubuntu5.10
Apache Release Year	Apache 2.2.8 released February 2008 — 18 years old
PHP Release Year	PHP 5.2.4 released August 2007 — PHP 5.x EOL since December 2018
Apache CVEs	Multiple CVEs for Apache 2.2.x including CVE-2017-7679 (mod_mime buffer overflow), CVE-2017-9788 (mod_auth_digest DoS)
PHP CVEs	PHP 5.2.4 has 100+ known CVEs including remote code execution vulnerabilities
Is Version Vulnerable?	YES — Both Apache 2.2.8 and PHP 5.2.4 are severely outdated EOL versions with many critical CVEs
Verdict	TRUE POSITIVE — HIGH/CRITICAL (Multiple CVEs, EOL software)

VERDICT: ALL THREE SERVICE FINDINGS: TRUE POSITIVE

5. Summary & Final Verdicts

The following table summarises all three Lab 3 validation findings with their final verdicts:

Finding	Service/Port	Scanner Said	Verdict	Technical Justification
A	SSL Cipher (Port 443)	Critical SSL weak	FALSE POSITIVE (Port 443) True Positive (Port 25/5432)	Port 443 is FILTERED — no HTTPS on Metasploitable2. SSL weakness is real but on ports 25 & 5432, not 443.
B	Bind Shell (Port 1524)	Critical No Auth	TRUE POSITIVE CRITICAL	Nmap confirms port 1524 open as 'bindshell'. Nessus AND Nmap both agree — backdoor confirmed. Root shell accessible immediately.
C	vsftpd 2.3.4 (Port 21)	High Outdated	TRUE POSITIVE CRITICAL	Banner grab confirms vsftpd 2.3.4 — THE backdoored version. CVE-2011-2523 is actively exploitable. Root shell on port 6200.
C	OpenSSH 4.7p1 (Port 22)	High Outdated	TRUE POSITIVE LOW/ACCEPTED	Banner confirms version. CVE-2008-5161 is low severity. Not exploitable via direct RCE. Accepted Risk with monitoring.
C	Apache 2.2.8 PHP 5.2.4 (Port 80)	High Outdated	TRUE POSITIVE CRITICAL	curl confirms Apache 2.2.8 + PHP 5.2.4. Both are EOL with 100+ CVEs including RCE vulnerabilities. Upgrade immediately.

5.1 Key Learning: This Is What Real VA Analysts Do

Every finding in this lab demonstrates why manual validation is essential:

- Finding A showed that a finding can be partly false — SSL is real, but not on port 443 specifically
- Finding B showed perfect confirmation — two independent tools agree on a critical backdoor
- Finding C showed version-based detection can be reliable if you verify the exact version via banner grab

Blind Reporting vs Professional Reporting:

Blind Reporter (Bad Analyst)	Copies Nessus output to Word document and submits
Professional Analyst (Good Analyst)	Runs Nmap, Netcat, curl to verify each finding manually before writing a single word
Blind Reporter Risk	Reports SSL on port 443 when it does not exist — wastes client remediation time and budget
Professional Analyst Value	Identifies that SSL issue is on ports 25/5432, not 443 — gives precise actionable information